

# OWASP Dependency-Check: How It Works, Benefits, and Pros/Cons

## What is OWASP Dependency-Check?

7 Minute Read

[OWASP Dependency-Check](#) is a tool that checks for known vulnerabilities in third-party libraries used by a software application. It does this by checking the dependencies of the application against the National Vulnerability Database (NVD), which is maintained by the US National Institute of Standards and Technology (NIST).

Dependency-Check can be run as a command-line tool or integrated into a build system, and it supports a wide range of programming languages including Java, .NET, and Python. By using Dependency-Check, you can identify and address vulnerabilities in the third-party libraries your application relies on, improving the security of your application.

In this article:

- [Why Is OWASP Dependency-Check Needed?](#)
- [OWASP Dependency-Check: How Does It Work?](#)
- [OWASP Dependency-Check: Pros and Cons](#)

## Why Is OWASP Dependency-Check Needed?

It is common for software applications to rely on third-party libraries to provide certain functionality. These libraries can make development faster and more efficient, as developers don't have to build everything from scratch. However, the use of third-party libraries also introduces risk, as the security of the application is now dependent on the security of the libraries it uses.

If a vulnerability is discovered in one of the libraries used by an application, an attacker could potentially exploit that vulnerability to compromise the security of the application. By using a

tool like OWASP Dependency-Check, you can identify and address vulnerabilities in the libraries your application relies on, helping to reduce the risk of a successful attack.

In addition to checking for known vulnerabilities, Dependency-Check can also help you identify when you are using an outdated version of a library that may have been superseded by a more secure version. This can help you ensure that your application is using the most secure versions of the libraries it depends on.

## OWASP Dependency-Check: How Does It Work?

Here's a detailed explanation of how Dependency-Check works:

1. **Collecting evidence:** Dependency-Check collects evidence about the dependencies used by an application by analyzing the application's code, configuration files, and other metadata.
2. **Identifying the Common Platform Enumeration (CPE):** For each dependency, Dependency-Check determines its Common Platform Enumeration (CPE) identifier, which is a standardized naming scheme for software and hardware products. The CPE identifier includes information about the vendor, product, and version of the dependency.
3. **Storing in a Lucene index:** Dependency-Check stores the collected evidence and CPE identifiers in a Lucene index, which is a search engine that allows Dependency-Check to quickly search and retrieve data.
4. **Comparing against a list of Common Vulnerability and Exposure (CVE) entries:** Dependency-Check compares the CPE identifiers of the dependencies to a list of Common Vulnerability and Exposure (CVE) entries in the NVD. A CVE entry is a standardized way of identifying and describing a vulnerability in a piece of software.
5. **Using the list of CVE entries:** If Dependency-Check finds a match between a dependency's CPE identifier and a CVE entry, it will use the information in the CVE entry to determine whether the dependency is vulnerable and, if so, to what extent.
6. **Expanding on the information:** Dependency-Check can also retrieve additional information about the vulnerability from other sources, such as the Common Vulnerability Scoring System (CVSS), which is a standardized method of scoring the severity of a vulnerability.
7. **Listing the comparison in an HTML or XML report:** Finally, Dependency-Check generates a report that lists the vulnerabilities it has identified, along with information about the affected dependencies and the severity of the vulnerabilities. The report can be generated in HTML or XML format.

By following this process, Dependency-Check is able to identify and report on vulnerabilities in the dependencies used by a software application. This can help developers and security professionals to identify and address vulnerabilities in their applications, improving the security of the applications.

# OWASP Dependency-Check: Pros and Cons

## Advantages of OWASP Dependency-Check:

- **Free and open source:** Dependency-Check is free to use and is released under an open source license, making it readily accessible to anyone who wants to use it.
- **Wide language support:** Dependency-Check supports a wide range of programming languages, including Java, .NET, and Python, making it a useful tool for a variety of applications.
- **Integration with build systems:** Dependency-Check can be integrated into build systems, allowing it to be run automatically as part of the build process.
- **Regular updates:** Dependency-Check is regularly updated with new vulnerability information, helping to ensure that it can identify the latest vulnerabilities.

## Disadvantages of OWASP Dependency-Check:

- **Limited to known vulnerabilities:** Dependency-Check can only identify vulnerabilities that are already known and listed in the NVD. If a new vulnerability is discovered in one of your dependencies that has not yet been added to the NVD, Dependency-Check will not be able to identify it.
- **May generate false positives:** Dependency-Check may generate false positives, meaning that it may report a vulnerability that does not actually exist. This can be caused by incorrect or outdated information in the NVD, or by differences in how Dependency-Check and the application interpret the dependency's CPE identifier.
- **May require manual intervention:** Dependency-Check can identify vulnerabilities, but it does not automatically fix them. It is up to the user to decide how to address the vulnerabilities, which may require manual intervention.

Related content: Read our guide to [OWASP top 10](#)

## Application Security with HackerOne

HackerOne and its community of ethical hackers is at the forefront of using OWASP to strengthen application security and make the Internet safer, referencing the OWASP Top 10 to prioritize their actions.

Taking this approach one step further, the HackerOne Global Top 10 can enable application security teams to increase their effectiveness with timely insights, segmented by industry and fueled by exploitable findings from ethical hackers. These findings might be new, or discovered by innovative techniques, and are unlikely to show up in the OWASP database. Combined, the OWASP and HackerOne exploit databases help you ensure that high severity vulnerabilities are found and fixed before bad actors can do damage.

Company

- Leadership
- Careers
- Partners
- Newsroom
- Contact Us

Knowledge

- Center
  - Application Security
  - Penetration Testing
  - Cloud Security
  - Hacking
  - Cybersecurity
  - Attacks
  - DevSecOps

Resources

- Blog
- Documentation
- Leaderboard
- Partner Portal
- Resources

Contacted  
by a  
hacker?

